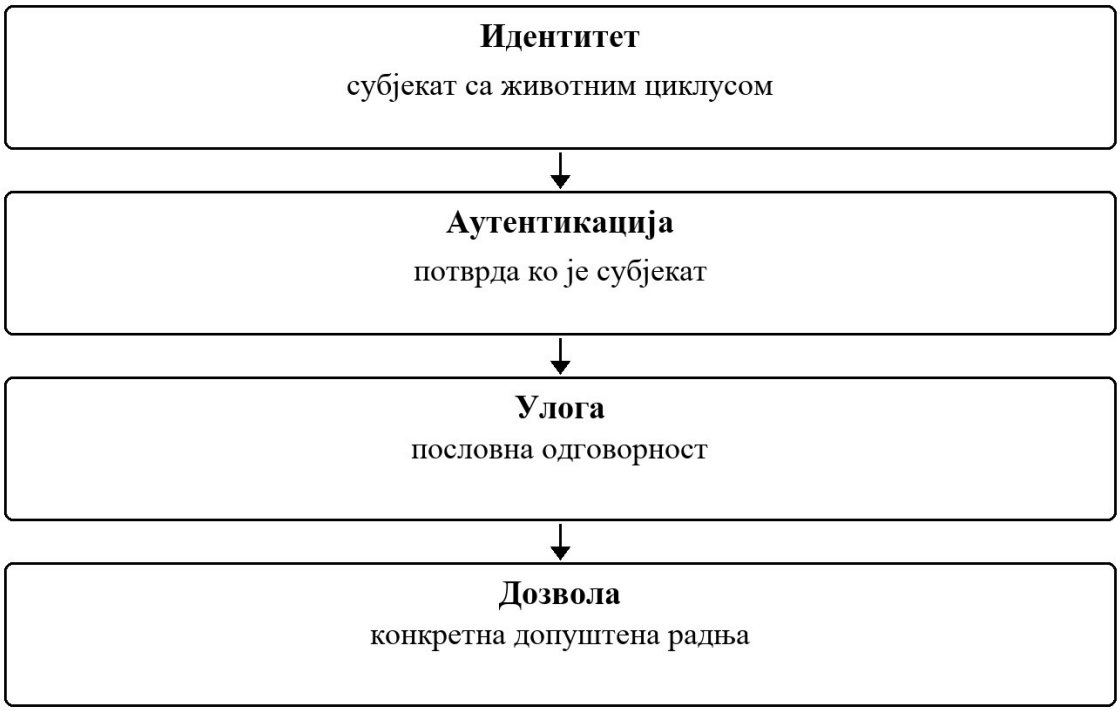
Идентитет, аутентикација и Контрола приступа заснована на улогама

Основе информационе безбедности · 01

Безбедност почиње раздвајањем идентитета, пријаве и овлашћења. Систем најпре треба да поуздано препозна субјекат, затим да процени његов актуелни статус, а тек потом да провери шта тај субјекат сме да уради. Када се ти кораци помешају, грешке се лако сакрију иза једне успешне пријаве.

Контрола приступа заснована на улогама је важан зато што права не додељује произвољно сваком налогу. Улоге изражавају одговорности у организацији, па тим може разумљиво да управља приступом, да га прегледа и да га укине када више није потребан.



Слика 1. Ко приступа систему и зашто идентитет претходи свакој одлуци

Безбедносна одлука настаје повезивањем приказаних појмова.

Циљ вежбе

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

1.1 Ментални модел приступа

Контрола приступа заснована на улогама је важан зато што права не додељује произвољно сваком налогу. Улоге изражавају одговорности у организацији, па тим може разумљиво да управља приступом, да га прегледа и да га укине када више није потребан.

- Успешна пријава потврђује идентитет, али сама по себи не даје право на ресурс.
- Улога треба да буде читљива пословна одговорност, а дозвола мала и проверљива радња.
- Промена статуса или улоге мења приступ одмах, без ослањања на застарелу претпоставку клијента.

Питање за дискусију

За једну административну радњу објасните разлику између идентитета, улоге, дозволе и опсега у коме дозвола важи.

1.2 Како се ова тема види у развоју

Дизајн почиње питањима ко су актери, које одговорности имају и над којим опсегом раде. Сервер доноси коначну одлуку; интерфејс само помаже кориснику да не бира радње које вероватно неће проћи.

Честе грешке које треба препознати

- Мешање аутентикације и ауторизације у једну проверу.
- Давање широке улоге зато што је брже од обликовања једне дозволе.
- Ослањање на сакривено дугме као на безбедносну контролу.

Веза са осталим темама

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

1.3 Пример: оператор добија нову одговорност

Оператер је до јуче прегледао извештаје, а данас привремено помаже тиму који одобрава промене на осетљивим ресурсима. Најједноставније решење делује као додела администраторске улоге. Међутим, та одлука често отвара много више радњи него што је стварно потребно, а касније је тешко утврдити које право је било оправдано и када треба да нестане.

- Прво се одређује конкретна радња коју оператор треба да изврши, а не назив најшире постојеће улоге.
- Затим се проверава опсег: да ли право важи за цео систем, један домен или само ограничено време.
- На крају се дефинише ревизија или истек, како привремена потреба не би остала трајна привилегија.

Критеријуми решења

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

1.4 Дизајнерска одлука: улога није дозвола

Улога је начин да организација групише одговорности, док дозвола изражава најмању радњу коју систем штити. То раздвајање делује као додатни посао на почетку, али смањује цену сваке касније промене. Када се дода нова радња, тим не мора да измишља нову комбинацију корисника и изузетака, већ процењује којој одговорности припада и над којим опсегом важи.

- Улоге треба именовати по одговорности, не по техничком слоју апликације.
- Дозвола треба да описује радњу и ресурс довољно прецизно да може да се провери.
- Ефективна права настају из улоге, опсега и актуелног статуса, а не из једног статичког поља корисника.

1.5 Како знамо да модел приступа ради

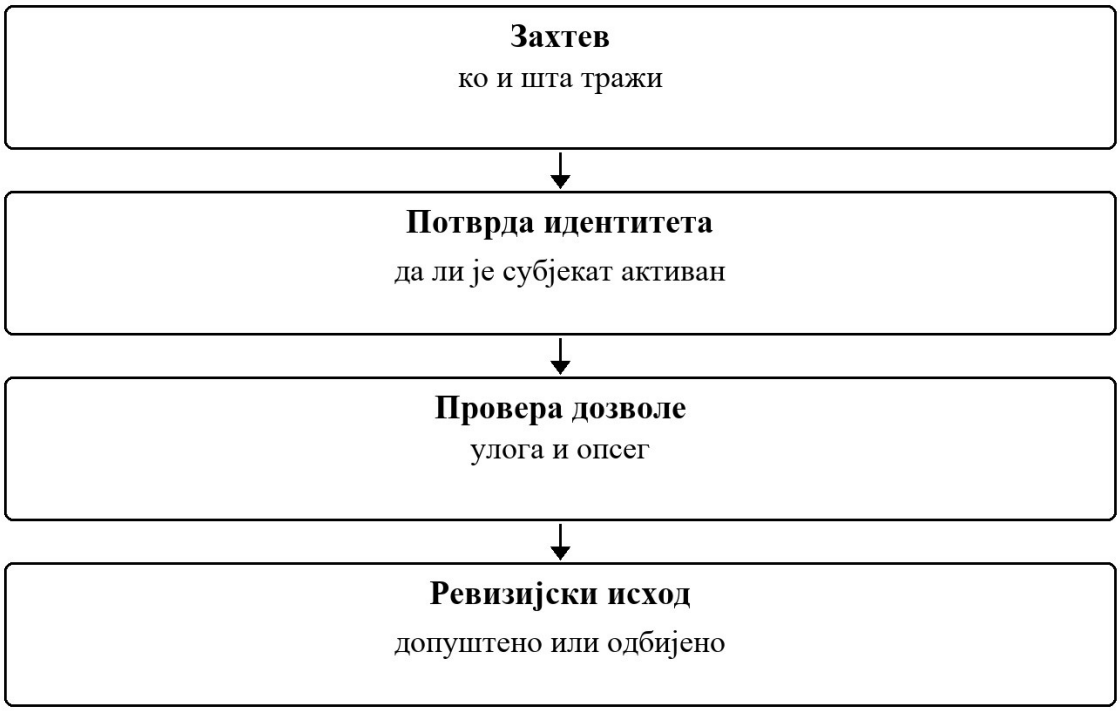
Најкориснији доказ није само успешна пријава. Потребно је показати и да систем одбија радњу када изостане једна потребна чињеница: активан идентитет, одговарајућа дозвола или исправан опсег. Такви негативни случајеви штите модел од случајног ширења права кроз касније измене.

- Тестови пореде очекивано допуштену и одбијену радњу над истим типом ресурса.
- Ревизијски запис бележи ко је покушао радњу, шта је захтевано и какав је исход.
- Преглед права треба да објасни основ приступа, а не само назив корисничке улоге.

Самостална провера

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

1.6 Шема одлуке о приступу



Слика 2. Шема одлуке о приступу

Пријава је само једна фаза. Право приступа настаје тек када систем провери цео контекст.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

1.7 Поређење основних појмова идентитета

Табела 1. Појам и Питање на које одговара

Појам	Питање на које одговара	Типична грешка
Идентитет	Ко је субјекат?	Мешање особе и техничког налога.
Аутентикација	Да ли је тврдња о идентитету потврђена?	Успешна пријава се тумачи као широко овлашћење.
Ауторизација	Да ли је радња допуштена?	Провера се ради само у корисничком интерфејсу.
Сесија	У ком привременом контексту приступ важи?	Токен се третира као трајно право.

Тумачење поређења

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

1.8 Ток размишљања при одлуци о приступу

Када систем прими захтев, корисно је посматрати одлуку као низ питања, а не као једну методу која враћа да или не. Свако питање смањује скуп могућих грешака и оставља јасан траг за каснији преглед.

1. Да ли је субјекат познат и активан?

2. Да ли је захтевана радња дефинисана као дозвола?

3. Да ли улога и опсег дају то право баш у овом тренутку?

4. Који ревизијски запис описује успех или одбијање?

Исход учења

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

Примена на пројекту

На додељеној пројектној целини применити принцип из теме „Идентитет, аутентикација и Контрола приступа заснована на улогама". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

1.9 Извршиви пример

Ауторизација приступа извештајима на основу улога. `RbacPolicy` подразумевано одбија приступ; пријављен налог мора имати тражену дозволу.

Пример 1. Покретање из репозиторијума наставног портала; потребан је дотнет 8 СДК.

```
cd examples/oib-dotnet/vezba-01-identitet-rbac
dotnet run --project src/Oib.Vezba01.ConsoleUi
dotnet test Oib.Vezba01.sln
```

Табела 2. Провера и Садржај

Провера	Садржај
Сценарио	Улога без дозволе `reports:export` покушава извоз.
Тестови	`RbacPolicyTests`, `AuthorizeAccessHandlerTests`
Доказ	`AccessAuditEntry` бележи и одобрен и одбијен приступ.

Задатак уз пример

Додати атрибут `IsActive` актеру и правило да деактивиран налог нема приступ иако има улогу. Правило додати у `RbacPolicy`, увести нов код одлуке и покрити га тестом.